

Log Injection QA Testing Checklist

ISEC3004 - Cyber Crime and Security Enhanced Programming

Component: Secure Logging - Feedback Functionality
Mitigation: CRLF Input Sanitisation and Output Neutralisation
Tester: Arindi Dulanya Liyanage
Purpose: Verify that legitimate feedback is accepted and logged normally, while carriage-return and line-feed characters submitted through the Python exploit or Burp Suite are escaped and cannot create forged log records.

Test Checklist

Test ID	Test Scenario	Test / Input	Expected Result	Actual Result	Status
LI-QA-01	Authenticated access to mitigated feedback form	Log in as the demo user and open /feedback in the security-enhanced application.	The feedback form is displayed for the authenticated user.	The mitigated feedback page displayed successfully for user 'student'.	PASS
LI-QA-02	Legitimate feedback remains functional	Submit: 'The mitigated application accepts normal feedback.'	The application accepts the feedback and displays the secure confirmation page.	The feedback was accepted and 'Feedback Submitted Safely!' was displayed.	PASS
LI-QA-03	Legitimate feedback produces one log record	Inspect app_mitigated.log after the normal submission.	The feedback is stored as one correctly structured INFO record.	The complete normal message appeared on one physical log line.	PASS

LI-QA-04	Python CRLF payload is neutralised in server output	Run log_injection_exploit.py against the security-enhanced application and inspect the server trace.	CR and LF characters appear as visible \r and \n sequences and do not create a new console record.	The server trace retained \r\n visibly within the submitted feedback value.	PASS
LI-QA-05	Python payload cannot forge a log entry	Inspect app_mitigated.log after executing the Python exploit.	The entire payload remains on one INFO line, no independent WARNING record is created.	The attacker-controlled warning remained inside the original INFO entry on one physical line.	PASS
LI-QA-06	URL-encoded Burp payload is processed safely	Intercept POST /feedback and submit a comment containing '%0D%0A' followed by a forged ERROR message.	The application processes the request while neutralising the decoded CRLF characters.	The application returned the secure confirmation page without creating an application error.	PASS
LI-QA-07	Burp payload cannot forge a log entry	Inspect app_mitigated.log after forwarding the modified Burp Suite request.	The decoded CRLF sequence is stored visibly as \r\n within one INFO record; no separate ERROR entry is created.	The forged ERROR text remained in the original INFO entry and no independent attacker-controlled record appeared.	PASS

Overall Result: PASS - Normal feedback functionality was preserved, and the Python and Burp Suite CRLF payloads were neutralised. Neither payload created an independent forged WARNING or ERROR entry in app_mitigated.log.

Evidence: evidence/arindi-log-injection-mitigation-tracing/01-mitigated-feedback-page.png through 10-burp-payload-sanitized-in-log.png, including application pages, Python execution, server output, Burp Suite request tracing and application-log captures.

Note: This checklist records tests that were completed during Log Injection mitigation verification. The implemented strategy safely escapes CR and LF characters rather than rejecting the complete HTTP request; therefore, a successful HTTP response is expected when the payload has been neutralised.